S&P Capital IQ PRO

Grupo Bimbo, S.A.B. de C.V. | ESG Scores Raw Data

BMV:BIMBO A (MI KEY: 4276592; SPCIQ KEY: 877906; TCUID: 53231)

Additional Disclosure

Year:	Methodology Year: 2020
Question:	Information Security Management Programs

Include Modeled Scores : Yes

Information Security Management Programs

Question

Does the company have programs on information security management?

Rationale

Due to the current trend of digitization, including but not limited to cloud computing, online market places and payments, etc., it is crucial that access to network, IT systems and data is assured at all times. As a result, lower than agreed upon system performance or service disruptions can result in higher costs and reputational risk for companies. The main risks stem from technical failure, human error, malicious attacks, weather events, natural disasters or terrorist attacks. Managing such risks, including contingency plans, is crucial to ensuring business continuity.

Over the past decade, the number of information security breaches has grown exponentially with some attacks reaching unprecedented scale and the cyber threat landscape continues to grow and evolve, abusing existing and new technologies and exploiting vulnerable users. These incidents and the related costs have shown that information security/cybersecurity has become a financially material issue which must be diligently managed to protect corporate value. The costs of cyberattack are manifold and can impact the company in different ways. Internal costs are operational costs and relate to dealing with cybercrime and incidence prevention. External costs include the consequences of the cyber-attack such as the loss or theft of sensitive information, operations' disruption, fines and penalties, infrastructure damage or revenue losses due to loss of customers. Thus, ensuring the security and resilience of netw

The question focuses on how well companies are prepared to prevent major IT infrastructure and information security/cybersecurity incidents and if they can react appropriately in the event of such events.

Performance Summary	
Question Level Company Performance	
Question Weight	
Year-on-Year Change	
Industry Average Score	
Industry Highest Score	

The question layout and the company's verified information is provided below. No information is shown if the company did not provide any information or if it opted out of sharing non-public information.

Additional Question Guidance & Information Display

▼ Additional Question Guidance & Information Display

Key Definitions

IT security: IT security is the process of implementing measures and systems designed to securely protect and safeguard information utilizing various forms of technology. IT security is thus considered a bit broader than cybersecurity.

Information System: Applications, services, information technology assets, or other information handling components (according to ISO).

Cybersecurity: Cybersecurity is the body of technologies, processes and practices designed to protect networks, systems, computers, programs and data from attack, damage or unauthorized access (according to SEC).

Information security: The protection of information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide confidentiality, integrity, and availability (according to NIST).

CISO: A chief information security officer (CISO) is the senior-level executive within an organization responsible for establishing and maintaining the enterprise vision, strategy, and program to ensure information assets and technologies are adequately protected. The chief information security officer (CISO), or alternatively the Chief Information Officer (CIO), is the highest ranking cyber security executive and is responsible for establishing and maintaining the enterprise strategy and processes that protect information assets.

CSO: A Chief Security Officer (CSO) is the employee responsible for the physical security of a company, including its communication and business systems. The job of a CSO is to protect people, assets, infrastructure and technology.

Experience: Relevant experience could be past experience in implementation of IT, information security or cybersecurity or operational responsibility for IT as a senior executive of a company.

In addition for Board Member - non-technical experience as a senior executive of an IT company (such as SVP Marketing, Sales etc.) is not valid. Academic experience in IT is not considered relevant.

Vulnerability analysis: The analysis that a company conducts for the defining, identifying, classifying and prioritizing vulnerabilities in computer systems, applications and network infrastructures and providing the organization doing the assessment with the necessary knowledge, awareness and risk background to understand the threats to its environment and react appropriately.

Important note: Throughout the whole criterion we always refer to IT security, cybersecurity or information security according to the definitions above. For the appraisal of the criterion we will treat "IT security", "information security" and "cybersecurity" equally.

Data Requirements

SASB – Data Security: "The entity shall describe its approach to addressing data security risks and vulnerabilities it has identified, including, but not limited to, operational procedures, management processes, structure of products, selection of business partners, employee training, and use of technology." Source: SASB

The registrant may choose to describe the degree to which its management approach is aligned with an external standard or framework for managing data security such as:

- ISO/IEC 27001:2013 – Information technology – Security techniques – Information security management systems – Requirements
- "Framework for Improving Critical Infrastructure Cybersecurity, Version 1.0," February 12, 2014, National Institute of Standards and Technology (NIST)

Data View

No information was found in the public domain.

Questionnaire

This question assesses if companies have the right processes in place to prevent IT system interruptions and cyberattacks and if they are well-prepared to react in case of such events.

1. ○

   Incident Response

   Do you have business continuity / contingency plans and incident response procedures in place and how often do you test them? Please provide supporting evidence.

   1. ○

      Yes, and we test them at least semi-annually
   2. ○

      Yes, and we test them at least annually
   3. ○

      Yes, but frequency is less than yearly or not specified
   4. ○

      No, we do not have such plans and procedures in place

   Certification

   Is your IT infrastructure and information security management system certified to ISO 27001, NIST or similar?

   1. ○

      Yes, the following percentage of our IT infrastructure has been certified:
   2. ○

      No, our IT infrastructure has not been certified.

   External Verification and Vulnerability Analysis

   Please indicate if there are other additional procedures implemented to assure the security of the IT infrastructure / information security management systems.

   1. ☐

      Our IT infrastructure and information security management systems have been audited by external auditors in the last fiscal year. Please provide letter of opinion from the external auditor.
   2. ☐

      We do vulnerability analysis including simulated hacker attacks. Please provide supporting evidence:
2. ○

   We do not have processes and infrastructure in place to prevent and/or respond to cyberattacks.
3. ○

   Not applicable. Please provide explanations in the comment box below.
4. ○

   Not known

Confidential additional comments

Use the text field below only in the following cases: (i) to describe significant changes in data or calculation methodology compared to last year's submission, (ii) to explain why a question is not applicable to your company's business model, (iii) to explain if your data deviates from the unit or format requested, or (iv) to provide supporting notes on translations of non-English references.